

LAB 5 — OWASP ZAP INTEGRATED ASSESSMENT, REMEDIATION AND RETEST

Student: Jamiu Abidemi Afolabi

Course: ICDFA Cybersecurity Practical Assessment

**Lab: Lab 5 — OWASP ZAP Integrated Assessment,
Remediation and Retest Capstone**

Assessment Period: 3–6 September 2026

Date Completed: 6/09/2026

Environment: Kali Linux / Isolated Virtual Machine

Primary Tool: OWASP ZAP

1. EXECUTIVE SUMMARY

1.1 Assessment Overview

Assessment Type: Authorised local web application security assessment

Assessment Targets:

- DVWA — <http://127.0.0.1:4280>
- OWASP Mutillidae II — <http://127.0.0.1:8888>

Objective:

The purpose of the assessment is to complete an end-to-end security assessment using DVWA and Mutillidae. The assessment will also combine scoped Zap analysis with manual validation, minimal-impact proof and impact mapping. The assessment will also include remediation and retesting.

1.2 Key Findings

Finding	Application	Category	Severity	Status
X-Content-Type-Options Header Missing	DVWA	Security Misconfiguration	Medium	Remediated
Path Traversal	Mutillidae II	Path Traversal	High	Remediation Recommended
Reflected XSS	Mutillidae II	Cross-Site Scripting	High	Remediation Recommended
Missing Anti-clickjacking Header	DVWA	Security Misconfiguration	Medium	Remediated

2. SCOPE, RULES OF ENGAGEMENT AND BASELINE

2.1 Assessment Scope

Application	Target	Environment
DVWA	http://127.0.0.1:4280	Local isolated lab
OWASP Mutillidae II	http://127.0.0.1:8888	Local isolated lab

The assessment scope was restricted to the two locally hosted vulnerable web applications listed above. No public or external systems were included in the assessment scope.

2.2 Out-of-Scope Activities

The following activities were excluded from testing:

- Public or external systems
- Unauthorised applications or hosts
- Database dumping
- Credential dumping
- Persistence
- Privilege escalation
- Lateral movement
- Destructive actions
- External callbacks
- Unrelated data access

Testing was restricted to the authorised local DVWA and OWASP Mutillidae II applications.

2.3 Rules of Engagement

The assessment was an authorised cybersecurity training exercise that was conducted against locally isolated DVWA and OWASP Mutillidae II web applications.

Testing was restricted to:

- <http://127.0.0.1:4280>
- <http://127.0.0.1:8888>

The OWASP ZAP runs Protected Mode with both applications included within the defined assessment context. The permitted activities for this lab include passive assessment, scoped crawling, manual validation of at least three findings, false-positive handling, minimal-impact proof, impact assessment, remediation, and retesting.

The assessment restricts database dumping, credential dumping, privilege escalation, destructive actions, lateral movement, and any attacks beyond the local authorised applications.

2.4 Baseline Environment

DVWA Status: The app was running and accessible through <http://127.0.0.1:4280>. The Docker container `dvwa-dvwa-1` was running at the time of the baseline check.

Mutillidae II Status: The app was running and accessible through <http://127.0.0.1:8888>. The Mutillidae II web container `www` was running at the time of the baseline check.

Network Isolation: The assessed web applications were exposed through loopback bindings on 127.0.0.1. DVWA was mapped to 127.0.0.1:4280 and Mutillidae II was mapped to 127.0.0.1:8888. This supported the local-only assessment boundary.

Snapshot/Reset Status: Yes. Snapshot was reset before the start of lab 5.

Background Services Checked: The local listening services were reviewed using `sudo ss -lntp`. The review identified Docker-published application ports, the ZAP proxy listener on 127.0.0.1:8080, local DNS services, CUPS and other local listeners. No external assessment target was intentionally selected from these services.

Baseline Evidence: E-06-Baseline-Environment

3. ZAP CONFIGURATION AND PASSIVE ASSESSMENT

3.1 ZAP Protected Mode

ZAP Version: 2.17.0

Mode: Protected

Protected Targets:

- <http://127.0.0.1:4280> — DVWA
- <http://127.0.0.1:8888> — OWASP Mutillidae II

Excluded Targets: None

Stop Conditions:

Testing was restricted to the authorised local DVWA and OWASP Mutillidae II applications. Testing was to stop if activity moved outside the defined local scope or if an action could result in destructive, persistent, or otherwise unauthorised impact.

Evidence: E-01-ZAP-Protected-Mode

3.2 ZAP Context and Scope

The assessment targets were placed within the same ZAP context to establish a defined testing boundary for the Lab 5 assessment.

DVWA

Context: Lab5-Local-Web-App

Included URLs:

- <http://127.0.0.1:4280>
- Resources beneath the DVWA application that matched the configured context scope

Excluded URLs: None

Evidence: E-02-ZAP-Context&Scope

OWASP Mutillidae II

Context: Lab5-Local-Web-App

Included URLs:

- <http://127.0.0.1:8888>
- Resources beneath the Mutillidae II application that matched the configured context scope

Excluded URLs: None

Evidence: E-02-ZAP-Context&Scope

3.3 Passive Assessment

DVWA

Pages/Functions Visited:

- <http://127.0.0.1:4280/favicon.ico>
- <http://127.0.0.1:4280/index.php>
- <http://127.0.0.1:4280/instructions.php>
- <http://127.0.0.1:4280/login.php>
- <http://127.0.0.1:4280/logout.php>
- <http://127.0.0.1:4280/phpinfo.php>
- <http://127.0.0.1:4280/setup.php>

Site Tree Observations:

ZAP discovered the DVWA application and recorded the above resources during normal application browsing. Some resources, including [login.php](#) and [setup.php](#), appeared more than once because they were accessed through multiple requests.

Passive Alerts Observed:

- Application Error Disclosure
- CSP: Failure to Define Directive with No Fallback
- CSP: Wildcard Directive
- CSP: style-src unsafe-inline
- Missing Anti-clickjacking Header
- Cross-Domain JavaScript Source File Inclusion
- Information Disclosure - Debug Error Messages

- Private IP Disclosure
- Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
- X-Content-Type-Options Header Missing
- Informational Risk: User Controllable HTML Element Attribute (Potential XSS)

Evidence: E-03-DVWA-Site-Tree

OWASP Mutillidae II

Pages/Functions Visited:

- <http://127.0.0.1:8888/index.php?do=logout>
- <http://127.0.0.1:8888/index.php?page=labs/lab-6.php>
- <http://127.0.0.1:8888/index.php?page=add-to-your-blog.php>
- <http://127.0.0.1:8888/index.php?page=edit-account-profile.php>
- <http://127.0.0.1:8888/index.php?page=login.php>
- <http://127.0.0.1:8888/index.php?page=user-info.php&username=jay&password=test&user-info-php-submit-button=View+Account+Details>
- <http://127.0.0.1:8888/set-up-database.php>
- <http://127.0.0.1:8888/index.php?popUpNotificationCode=AU1>
- <http://127.0.0.1:8888/index.php?do=logout>
- <http://127.0.0.1:8888/index.php?page=labs/lab-6.php>
- <http://127.0.0.1:8888/index.php?page=edit-account-profile.php&uid=41>

Site Tree Observations:

ZAP discovered multiple Mutillidae II application functions, including authentication, account-profile, user-information, blog/lab and database setup-related resources. Repeated resources indicate that some pages were accessed more than once during browsing.

Passive Alerts Observed:

- Absence of Anti-CSRF Tokens
- CSP: script-src unsafe-inline
- HTTP to HTTPS Insecure Transition in Form Post
- Sub Resource Integrity Attribute Missing
- Big Redirect Detected (Potential Sensitive Information Leak)
- Informational Risk: Cookie Poisoning
- Information Disclosure - Suspicious Comments

Evidence: E-04-Mutillidae-Site-Tree

3.4 Passive Alert Summary

Alert	Application	Risk	Confidence	Initial Assessment
Application Error Disclosure	DVWA	Medium	Medium	Requires manual validation
CSP: Failure to Define Directive with No Fallback	DVWA	Medium	High	Passive configuration observation
CSP: Wildcard Directive	DVWA	Medium	High	Passive configuration observation
CSP: style-src unsafe-inline	DVWA	Medium	High	Passive configuration observation
Missing Anti-clickjacking Header	DVWA	Medium	Medium	Requires validation

Cross-Domain JavaScript Source File Inclusion	DVWA	Low	Medium	Requires validation
Information Disclosure - Debug Error Messages	DVWA	Low	Medium	Requires manual validation
Private IP Disclosure	DVWA	Low	Medium	Requires validation
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	DVWA	Low	Medium	Passive information-disclosure observation
X-Content-Type-Options Header Missing	DVWA	Low	Medium	Passive security-header observation
User Controllable HTML Element Attribute (Potential XSS)	DVWA	Informational	Low	Requires manual validation; currently informational/potential
Absence of Anti-CSRF Tokens	Mutillidae II	Medium	Low	Requires manual validation
CSP: script-src unsafe-inline	Mutillidae II	Medium	High	Passive configuration observation

HTTP to HTTPS Insecure Transition in Form Post	Mutillidae II	Medium	Medium	Requires validation
Sub Resource Integrity Attribute Missing	Mutillidae II	Medium	High	Passive security observation
Big Redirect Detected (Potential Sensitive Information Leak)	Mutillidae II	Low	Medium	Requires manual validation
Cookie Poisoning	Mutillidae II	Informational	Low	Requires manual validation
Information Disclosure - Suspicious Comments	Mutillidae II	Informational	Medium	Requires manual validation

4. CONSTRAINED AUTOMATED ASSESSMENT

4.1 Spider/Crawl

DVWA

Target: <http://127.0.0.1:4280>

Scope: Lab 5 ZAP context

URLs/Paths Discovered:

The ZAP Spider discovered resources associated with the DVWA application as part of the scoped crawl. ZAP reported a combined total of **1,471 URLs found** across the crawl and **484 added nodes**. ZAP did not provide a separate final total for DVWA.

Result:

At the end of the can, the Spider processed the DVWA application and identified both text and non-text resources. Some resources associated with the DVWA host were marked as **Out of Context** by ZAP. These resources were not treated as authorised targets for subsequent automated assessment unless explicitly brought within the defined scope.

Evidence: E-07-Overall-ZAP-AutoScan

OWASP Mutillidae II

Target: <http://127.0.0.1:8888>

Scope: Lab 5 ZAP context

URLs/Paths Discovered:

The ZAP Spider discovered resources associated with the Mutillidae II application as part of the scoped crawl. ZAP reported a combined total of **1,471 URLs found** across the crawl and **484 added nodes**. ZAP did not provide a separate final total for Mutillidae II.

Result:

During the scan, the Spider processed the Mutillidae II application and identified both text and non-text resources. Some resources associated with the Mutillidae II host were marked as **Out of Context** by ZAP. These resources were not treated as authorised targets for subsequent automated assessment unless explicitly brought within the defined scope.

Evidence: E-07-Overall-ZAP-AutoScan

Overall Crawl Observation:

The ZAP Spider reported **1,471 URLs found** and **484 added nodes** during the crawl. The results were not separated by application in the Spider summary. The discovery of a URL did not by itself make that resource an authorised assessment target.

4.2 Reduced Active-Scan Policy

Applicati on	Target	Included Paths	Exclude d Paths	Scan Polic y	Attack Strengt h	Scan Duration	Eviden ce
DVWA	GET http://127.0.0.1:4280/login.php	GET /login.php	Other applicati on paths were not selected as active-sc an targets	Defa ult Polic y	Not availabl e in the ZAP interfac e used	Not displayed by ZAP; timestam ps recorded	E-08-D VWA-R educed -Active- Scan
OWASP Mutillidae II	GET http://127.0.0.1:8888/index.php?page=login.php	GET /index.php?page=login.php	Other applicati on paths were not selected as active-sc an targets	Defa ult Polic y	Not availabl e in the ZAP interfac e used	Not displayed by ZAP; timestam ps recorded	E-09-M utillidae -Reduc ed-Acti ve-Sca n

The active assessment was deliberately constrained to the selected login-page GET requests rather than launching an unrestricted active scan against the complete application. Both targets were associated with the [lab5](#) ZAP context and recursive scanning was disabled for the selected-path scans.

For DVWA, the constrained active scan generated **251 requests and 12 alerts**. For OWASP Mutillidae II, the constrained active scan generated **3682 requests and 18 alerts**. The difference in request volume reflects the applications' differing responses and resources associated with the selected targets.

5. ALERT VALIDATION AND MANUAL CONFIRMATION

5.1 Validation Method

Selected ZAP alerts were manually reviewed using the available request/response information and controlled tests against the authorised local applications. A normal baseline was compared with a modified request to determine whether the reported behaviour could be reproduced and whether a security impact was observable. Findings were classified as **validated** where the reported weakness and its effect were confirmed, or **informational/unconfirmed** where the alert could not be independently demonstrated. Testing was limited to minimal-impact, non-destructive actions within the authorised DVWA and Mutillidae II environments.

5.2 Finding 1 — X-Content-Type-Options Header Missing

Application: DVWA

Category: Security Misconfiguration / Security Headers

ZAP Alert: X-Content-Type-Options Header Missing

Affected URL/Path: `http://127.0.0.1:4280/about.php`

Affected Parameter: Not applicable

Baseline

Normal Input/Request:

`GET /about.php using curl -I http://127.0.0.1:4280/about.php`

Observed Behaviour:

The server returned `HTTP/1.1 200 OK`, but the response did not contain the `X-Content-Type-Options: nosniff` security header.

Modified Request

Controlled Test:

No exploit payload was required. The response headers were inspected to determine whether the recommended `X-Content-Type-Options` protection was present.

Observed Response/Effect:

The header remained absent from the baseline response, confirming the condition reported by ZAP.

Validation

Classification: Validated

Reason:

Manual inspection of the HTTP response confirmed that the `X-Content-Type-Options` header was missing, matching the ZAP alert.

Evidence: E-11-DVWA-X-Content-Type-Proof

Evidence Limitation

Testing was limited to confirming the missing security header. No browser-based MIME-sniffing exploitation or further client-side impact testing was performed.

5.2 Finding 2 — Path Traversal / Local File Inclusion

Application: OWASP Mutillidae II

Category: Path Traversal / Local File Inclusion

ZAP Alert: Path Traversal

Affected URL/Path: `http://127.0.0.1:8888/index.php`

Affected Parameter: `page`

Baseline

Normal Input/Request:

`http://127.0.0.1:8888/index.php?page=home.php`

Observed Behaviour:

The application loaded the normal Mutillidae home page and returned the expected HTML content.

Modified Request

Controlled Test:

`http://127.0.0.1:8888/index.php?page=/etc/passwd`

Observed Response/Effect:

The application returned contents of the local `/etc/passwd` file. The response included entries such as:

`root:x:0:0:root:/root:/bin/bash`

`www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin`

`phinius:x:1000:1000:./home/phinius:/bin/sh`

The result demonstrates that the **page** parameter can be manipulated to retrieve a local system file.

Validation

Classification: Validated

Reason:

The ZAP Path Traversal alert was manually confirmed by changing only the **page** parameter from the normal application page to **/etc/passwd**. The application returned identifiable contents of the local system file, providing direct evidence of unintended local file disclosure.

Evidence: E-12-Mutillidae-Path-Tranversal-Proof, E-12b-Mutillidae-Path-Tranversal-Proof

Evidence Limitation

Testing was deliberately limited to the benign **/etc/passwd** file to confirm local file disclosure. No attempts were made to access credentials, modify or delete files, execute commands, obtain a shell, or perform further exploitation.

5.3 Finding 3 — Reflected Cross-Site Scripting

Application: OWASP Mutillidae II

Category: Cross-Site Scripting (Reflected)

ZAP Alert: Cross Site Scripting (Reflected)

Affected URL/Path: `http://127.0.0.1:8888/index.php`

Affected Parameter: **page**

Baseline

Normal Input/Request:

`http://127.0.0.1:8888/index.php?page=home.php`

Observed Behaviour:

The application loaded the normal Mutillidae home page without executing any injected JavaScript.

Modified Request

Controlled Test:

ZAP identified the following payload in the `page` parameter:

```
" onmouseover="alert(1);
```

The URL-encoded request was:

```
http://127.0.0.1:8888/index.php?page=%22+onmouseover%3D%22alert%281%29%3B
```

Observed Response/Effect:

The injected event handler was reflected into the application's response. When the affected element was interacted with by moving the mouse over it, the browser executed the injected JavaScript and displayed an `alert(1)` popup.

Validation

Classification: Validated

Reason:

The ZAP Reflected XSS alert was manually confirmed using the exact payload identified by ZAP. The payload was reflected through the `page` parameter and executed in the browser when the affected element was interacted with. This demonstrates client-side JavaScript execution caused by attacker-controlled input.

Evidence: E-12-Mutillidae-Cross-Site-Scripting-Proof

Evidence Limitation

Testing was deliberately limited to a harmless JavaScript `alert(1)` proof-of-execution. No attempts were made to access cookies, session information, browser storage, credentials, or other sensitive data.

5.4 Finding 4 — Missing Anti-clickjacking Header

Application: DVWA

Category: Security Misconfiguration / Missing Security Header

ZAP Alert: Missing Anti-clickjacking Header

Affected URL/Path: `http://127.0.0.1:4280/login.php`

Affected Parameter: `X-Frame-Options` header

Baseline

Normal Input/Request:

```
curl -I http://127.0.0.1:4280/login.php
```

Observed Behaviour:

The DVWA login page returned a normal HTTP `200 OK` response. The response contained standard HTTP and session headers, but no `X-Frame-Options` header was present.

Modified Request

Controlled Test:

No application input was modified. The response headers were inspected directly to determine whether the anti-clickjacking security control was present.

```
curl -I http://127.0.0.1:4280/login.php
```

Observed Response/Effect:

The response did not contain an `X-Frame-Options` header. A second check against the DVWA `about.php` page also showed no `X-Frame-Options` header.

This indicates that the application does not provide the HTTP response header normally used to restrict the page from being embedded in frames.

Validation

Classification: Validated

Reason:

The ZAP alert was manually confirmed by inspecting the HTTP response headers from DVWA. The affected page returned successfully but did not include the expected `X-Frame-Options` anti-clickjacking header. The same absence was observed on another DVWA page, providing additional confirmation that the security control was not present.

Evidence: E-13-DVWA-Anti-Clickjacking-Proof

Evidence Limitation

Testing was limited to confirming the absence of the anti-clickjacking response header. No clickjacking attack, malicious framing page, credential capture, or other exploitation was performed.

5.5 False-Positive / Informational Alert Analysis

Alert Reviewed

Application: DVWA

ZAP Alert: Information Disclosure - Suspicious Comments

Risk: Informational

Confidence: Medium

Affected URL/Path:

http://127.0.0.1:4280/setup.php

Manual Review

The flagged DVWA **setup.php** page was manually inspected using a direct HTTP request:

```
curl -s http://127.0.0.1:4280/setup.php
```

The response contained an HTML comment:

```
<!-- Create db button -->
```

The comment was associated with the database setup form and did not contain credentials, authentication information, secrets, or other sensitive data.

Classification

Classification: Informational

Reason:

The alert was manually reviewed and the reported comment was confirmed to be present in the application's HTML response. However, the identified comment contained only a descriptive reference to the database setup button and did not disclose sensitive information. It was therefore retained as an informational observation rather than promoted to a confirmed security finding.

Evidence Limitation

The review was limited to the specific suspicious comment identified by ZAP. No attempt was made to extract credentials, access restricted configuration files, or exploit other information disclosed by the setup page.

6. INTEGRATED MANUAL SECURITY ASSESSMENT

6.1 Validated Finding Summary

The manual assessment was used to confirm selected ZAP alerts and determine whether they represented observable security issues within the controlled lab environment. Four findings were manually validated across DVWA and OWASP Mutillidae II.

Finding	Application	ZAP Alert	Risk	Manual Validation Result
Finding 1	DVWA	X-Content-Type-Options Header Missing	Medium	Validated
Finding 2	OWASP Mutillidae II	Path Traversal	High	Validated
Finding 3	OWASP Mutillidae II	Cross Site Scripting (Reflected)	High	Validated
Finding 4	DVWA	Missing Anti-clickjacking Header	Medium	Validated

Summary of Validation

- **Finding 1:** The missing **X-Content-Type-Options** header was confirmed through inspection of the DVWA HTTP response.
- **Finding 2:** Path Traversal was confirmed when the **page** parameter was manipulated to request **/etc/passwd**, resulting in identifiable local file contents being returned.
- **Finding 3:** Reflected XSS was confirmed when the controlled payload supplied through the **page** parameter was reflected and executed as JavaScript, producing the expected **alert(1)** popup.
- **Finding 4:** The Missing Anti-clickjacking Header alert was confirmed through HTTP response inspection. The DVWA response did not contain an **X-Frame-Options** header.

- The assessment was deliberately limited to controlled proof-of-concept validation. No credential theft, destructive actions, persistence, or unauthorised external systems were involved.

The separate **Information Disclosure – Suspicious Comments** alert was reviewed as an informational observation and was not promoted to a confirmed finding.

7. IMPACT MAPPING

7.1 Application Privilege

DVWA

Application/Process Privilege:

DVWA runs as an Apache/PHP web application inside Docker. The exact process account was not checked.

Observed Access:

The testing confirmed missing security headers. No system files, commands or host resources were accessed.

Potential Blast Radius:

The missing headers could weaken browser protections and increase exposure to issues such as clickjacking or content-type sniffing.

Mutillidae II

Application/Process Privilege:

Mutillidae II runs as an Apache/PHP web application inside Docker. The exact process account was not checked.

Observed Access:

Path Traversal exposed `/etc/passwd`, and Reflected XSS successfully triggered a harmless `alert(1)`.

Potential Blast Radius:

Path Traversal could expose other files accessible to the application. XSS could allow attacker-controlled JavaScript to run in a user's browser.

7.2 Observed vs Potential Impact

Finding	Observed Impact	Potential Impact	Evidence Boundary
Finding 1 — X-Content-Type-Options Missing	Header was missing from the DVWA response.	Reduced browser protection against content sniffing.	Header check only.
Finding 2 — Path Traversal	<code>/etc/passwd</code> was returned by Mutillidae II.	Other readable files could potentially be exposed.	Only <code>/etc/passwd</code> was tested.
Finding 3 — Reflected XSS	<code>alert(1)</code> executed successfully.	Attacker-controlled JavaScript could run in a user's browser.	Harmless payload only.
Finding 4 — Anti-clickjacking Header Missing	<code>X-Frame-Options</code> was missing from the DVWA response.	Increased exposure to clickjacking.	Header check only.

Assessment Limitation

Testing was limited to the controlled Docker lab. No privilege escalation, persistence, lateral movement or unrelated data access was performed.

8. REMEDIATION AND RETEST

The findings were reviewed and possible fixes were identified. The two DVWA header findings were fixed and tested again. The two Mutillidae II findings were documented with their recommended fixes.

Finding	Application	Remediation	Status	Retest Evidence
Finding 1 — X-Content-Type-Options Header Missing	DVWA	Added the <code>X-Content-Type-Options: nosniff</code> header in Apache.	Remediated	The header was present in the HTTP response after the fix.
Finding 2 — Path Traversal	Mutillidae II	Limit the <code>page</code> input so users cannot request files outside the allowed pages.	Remediation Recommended	The original test showed that <code>/etc/passwd</code> could be read.
Finding 3 — Reflected XSS	Mutillidae II	Check and safely handle the <code>page</code> input so JavaScript cannot be executed in the browser.	Remediation Recommended	The original test showed that the harmless <code>alert(1)</code> payload executed.
Finding 4 — Missing Anti-clickjacking Header	DVWA	Added the <code>X-Frame-Options: SAMEORIGIN</code> header in Apache.	Remediated	The header was present in the HTTP response after the fix.

Retest Summary

The two DVWA header findings were fixed and confirmed through HTTP response checks.

The Mutillidae II findings were not fully fixed and retested. Their recommended fixes have been documented.

All testing was performed in the controlled lab environment. No privilege escalation, persistence, lateral movement or destructive testing was performed.

9. FINDING PRIORITISATION

Priority	Finding	Application	Likelihood	Observed Impact	Overall Risk	Remediation Status
1	Path Traversal	Mutillidae II	High	<code>/etc/passwd</code> was accessible.	High	Remediation Recommended
2	Reflected XSS	Mutillidae II	High	The <code>alert(1)</code> payload executed in the browser.	High	Remediation Recommended
3	X-Content-Type-Options Header Missing	DVWA	Medium	Browser protection was reduced.	Medium	Remediated
4	Missing Anti-clickjacking Header	DVWA	Medium	The application could be more exposed to clickjacking.	Medium	Remediated

Prioritisation Summary

The Mutillidae II Path Traversal and Reflected XSS findings were given the highest priority because they were successfully demonstrated and had a higher potential impact.

The DVWA header findings were lower priority and were successfully fixed and retested.

10. CLEANUP AND RESTORATION

Scans Stopped: Yes

Background Tools Stopped: Yes

Learner-Created Markers Removed: Yes

Stored Entries Removed: Yes

Test Sessions Cleared: Yes

Applications Reset: Yes

Clean Snapshot Restored: Yes

11. ANALYSIS QUESTIONS

11.1 Which validated finding presents the greatest observed risk, and why?

The **Path Traversal finding in Mutillidae II** presents the greatest observed risk. The test allowed `/etc/passwd` to be read from the application. This showed that an attacker could access files that should not be available through the web application.

11.2 Which ZAP alert required the most manual interpretation?

The **Path Traversal alert** required the most manual interpretation. It was necessary to confirm that the reported issue could actually be used to access a local file and that the result was not just a ZAP warning.

11.3 What is the difference between automated discovery and a confirmed finding?

Automated discovery means that ZAP has detected something that may be a security problem. A confirmed finding means that the issue was tested manually and the expected behaviour was observed.

11.4 What did the retest prove, and what residual risk remains?

The retest proved that the two DVWA security header issues had been fixed. The required headers were present in the HTTP responses after the changes.

The Path Traversal and Reflected XSS issues in Mutillidae II were not fully remediated and retested. These remain as residual risks.

12. CONCLUSION

The assessment identified four validated security findings across DVWA and Mutillidae II. The findings included two missing security headers in DVWA, Path Traversal in Mutillidae II, and Reflected XSS in Mutillidae II.

The Mutillidae II findings presented the more serious risks because the testing showed access to `/etc/passwd` and successful execution of a harmless JavaScript payload.

The two DVWA header findings were remediated and successfully retested. The Mutillidae II findings were documented with recommended remediation steps but were not fully retested.

Overall, the assessment showed the value of combining automated ZAP scanning with manual testing. ZAP helped identify possible weaknesses, while manual testing confirmed which findings were real and demonstrated their actual impact within the controlled lab environment.

APPENDIX A — ACTIVITY LOG

Check [activitylog.md](#)

APPENDIX B — EVIDENCE REGISTER

Check [evidenceregister.md](#)

APPENDIX C — ZAP OUTPUTS & Supporting Evidence

Check [Screenshots](#)